Report: Password Cracking

Introduzione e Obiettivo dell'Esercizio

L'obiettivo di questo laboratorio è simulare un attacco di Password Cracking per recuperare le password in chiaro a partire dai loro hash, salvati in modo non sicuro all'interno del database di un'applicazione web vulnerabile (DVWA - Damn Vulnerable Web Application).
L'esercizio si suddivide in due fasi principali: l'estrazione degli hash dal database tramite SQL Injection e il successivo cracking degli hash utilizzando il tool John the Ripper.

Fase 1: Estrazione delle Password Hash dal Database

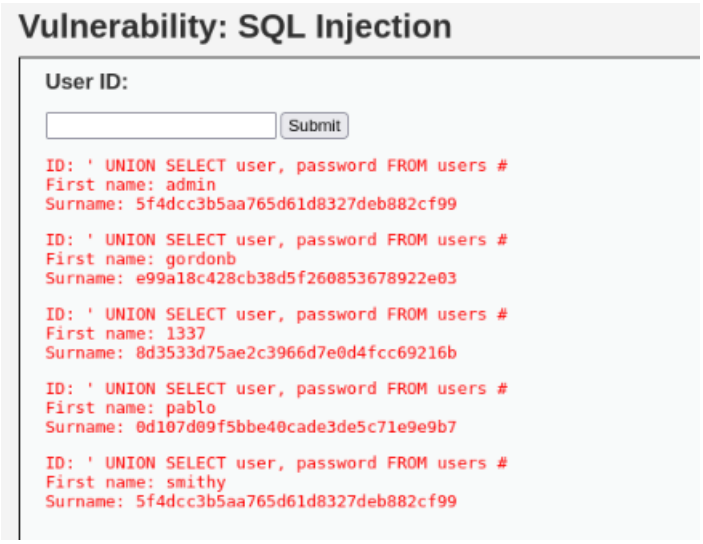
Per estrarre le password, è stato necessario sfruttare una vulnerabilità di tipo SQL Injection presente nella sezione "SQL Injection" di DVWA.

Impostando il livello di sicurezza dell'applicazione su "Low", è stato possibile iniettare il seguente payload nel campo "User ID":

' UNION SELECT user, password FROM users #

Spiegazione del payload:

- ' : Chiude la stringa della query originale.
- UNION SELECT : Permette di unire il risultato della query originale con una nuova query personalizzata.
- user, password : Specifica le colonne della tabella users che vogliamo estrarre.
- # : Commenta e ignora il resto della query originale, evitando errori di sintassi SQL.



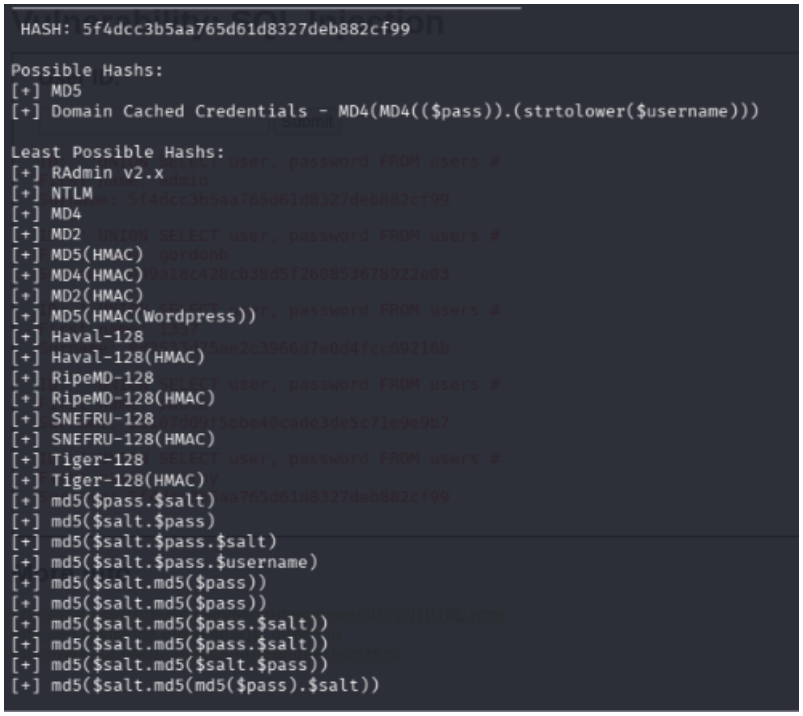
Fase 2: Identificazione e Preparazione del File

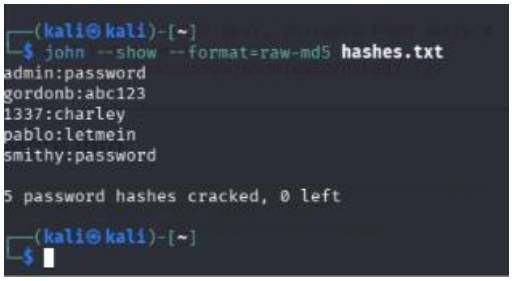
Una volta estratti gli hash sono stati salvati in un file di testo chiamato hashes.txt, strutturato nel formato nome_utente:hash, richiesto da John the Ripper.



Fase 3: Esecuzione del Cracking con John the Ripper

- Per recuperare le password in chiaro, è stato utilizzato **John the Ripper.**
- È stata utilizzata la wordlist **rockyou.txt**, (che contiene milioni di password comuni). Poiché gli hash estratti sono di tipo MD5, è stato specificato il formato corretto tramite il parametro **--format=raw-md5.**
- Comando utilizzato**: john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt**
- Per vedere i risultati: **john --show --format=raw-md5 hashes.txt**





Fase 4: Verifica Finale (Login con credenziali rubate)

Per dimostrare l'efficacia dell'attacco e la correttezza delle password recuperate, è stato effettuato un tentativo di login sull'applicazione DVWA utilizzando le credenziali dell'utente "gordonb".

- **Username:** gordonb
- **Password:** abc123

